

SAVR Post-Phase-6 Corrective Build Path

Repository:

GooseyPrime/SAVR

Starting main commit:

3373f4711b5c4887edc85d8eed780fecb8246121

Global execution rules

1. Run one task at a time.
2. Every task starts from the latest merged `main`.
3. Every task creates its own draft pull request.
4. Do not run these tasks concurrently.
5. Never auto-merge.
6. Copilot must read:
7. `/AGENTS.md`
8. `/.github/copilot-instructions.md`
9. applicable `.github/instructions/*.instructions.md`
10. relevant ADRs and architecture documents
11. After Corrective PR 1, never modify:
12. `SAVR-old/**`
13. `savr-premium-mobile-app/**`
14. Production code changes belong only in:
15. `savr-platform/**`
16. Every PR report must include:
17. exact files changed
18. exact commands executed
19. exact results
20. remaining limitations
21. confirmation that both reference folders remain unchanged
22. Do not weaken validation, security, RLS, authentication, billing, or TypeScript checks.

23. Do not add placeholder callbacks, mock production behavior, silent fallbacks, or client-authoritative entitlement logic.

Corrective PR 1 — Restore repository governance

Branch

```
copilot/corrective-01-governance
```

Pull request title

```
fix: restore reference integrity and Copilot instruction routing
```

Objective

Restore the two reference folders to their imported snapshots, correct Copilot path-specific instruction routing, prevent future reference mutations, and restrict dependency automation to the canonical platform.

Required work

A. Restore modified reference files

Restore these exact files from commit:

```
add8dd5c125ee27c6620897eec598d13920b4ce6
```

Files:

```
SAVR-old/mobile/package.json
SAVR-old/mobile/package-lock.json
SAVR-old/web/package.json
SAVR-old/web/package-lock.json
savr-premium-mobile-app/package.json
savr-premium-mobile-app/package-lock.json
```

Use the historical commit as the source. Do not reconstruct their contents manually.

Do not change any other file inside either reference folder.

B. Correct Copilot instruction frontmatter

Change every `applyTo` block from a YAML array with `../../..` paths to one quoted repository-root glob string.

Use these exact scopes:

```
.github/instructions/reference-production.instructions.md
```

```
---  
applyTo: "SAVR-old/**"  
---
```

```
.github/instructions/reference-ui.instructions.md
```

```
---  
applyTo: "savr-premium-mobile-app/**"  
---
```

```
.github/instructions/platform.instructions.md
```

```
---  
applyTo: "savr-platform/**"  
---
```

```
.github/instructions/platform-web.instructions.md
```

```
---  
applyTo: "savr-platform/web/**"  
---
```

```
.github/instructions/platform-mobile.instructions.md
```

```
---  
applyTo: "savr-platform/mobile/**"  
---
```

```
.github/instructions/platform-supabase.instructions.md
```

```
---  
applyTo: "savr-platform/supabase/**,savr-platform/web/lib/supabase*.ts,savr-  
platform/web/lib/db.ts,savr-platform/mobile/src/config/supabase.ts,savr-  
platform/mobile/src/lib/db.ts"  
---
```

```
.github/instructions/platform-ai.instructions.md
```

```
---  
applyTo: "savr-platform/web/app/api/ai/**,savr-platform/web/lib/services/  
ai*.ts,savr-platform/web/lib/config/forbiddenFoods.ts,savr-platform/mobile/src/  
utils/api.ts"  
---
```

```
.github/instructions/platform-payments.instructions.md
```

```
---  
applyTo: "savr-platform/web/app/api/stripe/**,savr-platform/web/lib/  
stripe.ts,savr-platform/web/app/pricing/**,savr-platform/web/contexts/  
AuthContext.tsx,savr-platform/mobile/src/types/index.ts,savr-platform/mobile/  
src/screens/main/ProfileScreen.tsx"  
---
```

Preserve the substantive instructions beneath the frontmatter.

C. Add instruction validation

Create:

```
scripts/validate-copilot-instructions.mjs
```

It must fail when:

- an instruction file lacks frontmatter
- `applyTo` is not one quoted string
- an `applyTo` value contains `../`
- an instruction filename does not end in `.instructions.md`
- an `applyTo` value is empty

Add this check to the repository-structure workflow.

D. Add immutable-reference verification

Create:

```
scripts/verify-reference-integrity.sh  
.github/workflows/reference-integrity.yml
```

The script must compare both reference directories to:

```
add8dd5c125ee27c6620897eec598d13920b4ce6
```

It must fail on any content difference.

The workflow must use full Git history:

```
fetch-depth: 0
```

It must run on every push and pull request.

E. Restrict Dependabot

Create:

```
.github/dependabot.yml
```

Configure npm dependency updates only for:

```
/savr-platform/web  
/savr-platform/mobile  
/savr-platform/e2e-tests
```

Do not configure updates for either reference folder.

For core frameworks, ignore automatic semver-major upgrades:

```
next  
react  
react-dom  
expo  
react-native
```

Major framework upgrades require an ADR and a dedicated PR.

F. Correct project tracking

Update `SOURCE_ORIGINS.md`:

- Keep both imported reference roles.
- Record the immutable snapshot commit used by the consolidated repository.
- Remove the outdated claim that `savr-platform` is uninitialized.
- Mark `savr-platform` as the canonical, initialized application.
- State that reference-integrity CI enforces the snapshots.

Update `MIGRATION_STATUS.md`:

- Preserve Phase 6 as complete.
- Add a section titled `Post-Phase-6 Corrective Track`.
- Mark governance restoration as the current corrective task.
- Do not rewrite the historical phase summaries during this PR.

Required validation

```
node scripts/validate-copilot-instructions.mjs
bash scripts/verify-reference-integrity.sh
git diff --exit-code add8dd5c125ee27c6620897eec598d13920b4ce6 -- SAVR-old savr-
premium-mobile-app
git status --short
```

Also verify the repository-structure and reference-integrity workflows pass.

Completion requirements

- Both reference directories exactly match the pinned snapshot.
- All instruction files use valid repository-root glob strings.
- Dependency automation cannot modify either reference repository.
- No `savr-platform` dependencies or application code changed.

Corrective PR 2 — Normalize Basic and Pro billing

Branch

```
copilot/corrective-02-billing-contract
```

Pull request title

fix: establish Basic and Pro as the only SAVR billing tiers

Authoritative pricing contract

There are exactly two plans and four recurring prices:

Plan	Monthly	Yearly
Basic	\$4.99	\$49.99
Pro	\$9.99	\$99.99

Use USD.

There is no Free, Plus, or Premium plan.

The existing five-day trial remains unchanged unless separately authorized.

A user with `pending`, `canceled`, `past_due`, `incomplete`, `incomplete_expired`, or `unpaid` status is not entitled merely because their tier says Basic or Pro.

Required work

A. Resolve ADR-001

Update:

```
docs/decisions/ADR-001-billing-tier-names.md
```

Set its status to `Accepted`.

Record the decision:

- `basic` and `pro` are the only canonical tier values.
- `free` maps to `basic`.
- `plus` maps to `pro`.
- `premium` maps to `pro`.
- Active access requires `active` or `trialing` status.
- Pro-only access requires both:
 - tier `pro`
 - active or trialing status

B. Add a forward-only Supabase migration

Do not modify the original migration.

Create a new dated migration under:

```
savr-platform/supabase/migrations/
```

The migration must:

1. Normalize existing rows:
2. `free` → `basic`
3. `plus` → `pro`
4. `premium` → `pro`
5. Remove the old tier check constraint.
6. Add a check constraint allowing only:
7. `basic`
8. `pro`
9. Keep the default tier as `basic`.
10. Run in a transaction.
11. Validate successfully through `supabase db reset`.

Discover and use the actual existing constraint name. Do not guess without validating it locally.

C. Create canonical billing helpers

Create:

```
savr-platform/web/lib/billing.ts  
savr-platform/mobile/src/lib/billing.ts
```

Both must expose equivalent semantics:

```
type SubscriptionTier = 'basic' | 'pro';  
  
function isKnownTier(value: unknown): value is SubscriptionTier;  
function isSubscriptionActive(status: string | null | undefined): boolean;
```



```
function hasBasicAccess(userData): boolean;  
function hasProAccess(userData): boolean;
```

Rules:

- Basic access is granted to active/trialing Basic or Pro users.
- Pro access is granted only to active/trialing Pro users.
- Unknown or legacy values grant no access.
- Tier alone never grants access.

Update all canonical web and mobile consumers to use these helpers.

Do not duplicate ad hoc entitlement comparisons across pages.

D. Remove legacy runtime tier values

Update canonical code only:

```
savr-platform/web/contexts/AuthContext.tsx  
savr-platform/web/lib/middleware.ts  
savr-platform/web/app/pricing/page.tsx  
savr-platform/mobile/src/types/index.ts  
savr-platform/mobile/src/contexts/AuthContext.tsx  
savr-platform/mobile/src/screens/main/ProfileScreen.tsx  
savr-platform/mobile/tests/subscription.test.ts
```

Search all of `savr-platform` for:

```
free  
plus  
premium
```

Runtime code must not accept these as valid tier values.

They may remain only in:

- the data-normalization migration
- ADR history
- explicit legacy-migration tests

Remove `as any` from mobile subscription-tier mapping.

E. Use explicit Stripe price IDs

Add server-only variables:

```
STRIPE_PRICE_BASIC_MONTHLY=  
STRIPE_PRICE_BASIC_YEARLY=  
STRIPE_PRICE_PRO_MONTHLY=  
STRIPE_PRICE_PRO_YEARLY=
```

Update relevant `.env.example` and deployment documentation.

Do not prefix these with `NEXT_PUBLIC_`.

Keep:

```
NEXT_PUBLIC_STRIPE_PRICING_TABLE_ID=  
NEXT_PUBLIC_STRIPE_PUBLISHABLE_KEY=
```

for the client-side Stripe pricing table.

F. Correct webhook tier resolution

Replace the current price inference.

The webhook must:

1. Match the Stripe price ID against the four configured server variables.
2. Return `basic` only for the two Basic price IDs.
3. Return `pro` only for the two Pro price IDs.
4. Reject an unknown price ID.
5. Never infer a tier from “nonzero amount.”
6. Never silently default an unknown price to Basic or Pro.
7. Avoid updating the user when price resolution fails.
8. Log only safe identifiers, never secrets.

Add validation for the expected Stripe price properties:

Price	Amount	Interval
Basic monthly	499 cents	month
Basic yearly	4999 cents	year
Pro monthly	999 cents	month
Pro yearly	9999 cents	year

All prices must use currency `usd`.

G. Correct the public pricing presentation

The public pricing page must visibly show:

- Basic — \$4.99/month
- Basic — \$49.99/year
- Pro — \$9.99/month
- Pro — \$99.99/year

It may continue using the Stripe pricing-table component for checkout.

Add static SAVR-controlled plan comparison content so visitors can see pricing before signing in and when Stripe's script is unavailable.

Preserve current feature entitlements. Do not invent new differences between Basic and Pro.

H. Add tests

Add tests covering:

- Basic active
- Basic trialing
- Basic pending
- Basic canceled
- Pro active
- Pro trialing
- Pro past due
- unknown tier
- legacy tier values rejected
- every configured Stripe price maps correctly
- unknown Stripe price throws
- amount alone cannot select a tier
- database constraint rejects legacy values

Update Playwright smoke coverage to verify all four displayed prices.

Required validation

```
cd savr-platform
npx supabase@latest db reset

cd web
npm ci
npm run lint
npm run typecheck
npm run test:unit
CI=true
```

```
NEXT_PUBLIC_SUPABASE_URL=https://dummy.supabase.co
NEXT_PUBLIC_SUPABASE_ANON_KEY=dummy_key_for_build
npm run build

cd ../mobile
npm ci
npm run lint
npm run typecheck
npm run test:unit

cd ../e2e-tests
PLAYWRIGHT_USE_WEBSERVER=true
CI=true
NEXT_PUBLIC_SUPABASE_URL=https://dummy.supabase.co
NEXT_PUBLIC_SUPABASE_ANON_KEY=dummy_key_for_build
npm run test:e2e:smoke
```

Also run:

```
rg -n "subscription_tier|subscriptionTier|free|plus|premium" savr-platform
```

Document every remaining legacy match.

Corrective PR 3 — Make Stripe webhook processing reliable

Branch

```
copilot/corrective-03-stripe-reliability
```

Pull request title

```
fix: add idempotent Stripe webhook reconciliation
```

Objective

Prevent duplicated Stripe webhook delivery from causing inconsistent processing and add repeatable billing reconciliation tests.

Required work

A. Add webhook-event persistence

Create a migration for:

```
public.stripe_webhook_events
```

Required columns:

```
event_id      text primary key
event_type    text not null
processing_status text not null
attempt_count integer not null default 1
last_error    text
created_at    timestamptz not null
processed_at  timestamptz
updated_at    timestamptz not null
```

Allowed processing statuses:

```
pending
processed
failed
```

Client users must not have direct access to this table.

B. Add an atomic claim mechanism

Create a server-only SQL function or RPC that:

- inserts a new pending event
- returns whether the caller acquired processing ownership
- returns already-processed for completed duplicates
- permits retrying previously failed events
- increments attempt count safely
- is race-safe for duplicate simultaneous deliveries

C. Update the webhook route

Processing order:

1. Verify Stripe signature.
2. Atomically claim the event ID.

3. Return success immediately for an already-processed duplicate.
4. Process the event.
5. Mark it processed.
6. On failure:
7. record a sanitized error
8. mark failed
9. return a non-2xx response so Stripe retries

Preserve the Basic/Pro mapping established by Corrective PR 2.

D. Add tests

Cover:

- invalid signature
- missing signature
- first valid delivery
- duplicate processed delivery
- retry after failed delivery
- Basic monthly
- Basic yearly
- Pro monthly
- Pro yearly
- unknown price ID
- subscription update
- subscription deletion
- payment failed
- payment recovered

No live Stripe key may be required for unit tests.

Use fixtures and mocked Stripe objects.

Corrective PR 4 — Formalize and validate the mobile platform version

Branch

```
copilot/corrective-04-mobile-platform
```

Pull request title

chore: validate and document the canonical Expo mobile platform

Objective

Resolve the undocumented transition of `savr-platform/mobile` to Expo 57 and React Native 0.86 without modifying the restored Expo 54 reference repository.

Required work

A. Preserve the reference

Do not modify:

SAVR-old/mobile/**

B. Audit the canonical mobile versions

Inspect:

```
savr-platform/mobile/package.json
savr-platform/mobile/package-lock.json
savr-platform/mobile/app.config.ts
savr-platform/mobile/app.json
savr-platform/mobile/eas.json
```

Verify compatibility among:

- Expo
- React Native
- React
- navigation packages
- camera
- image picker
- auth session
- Supabase
- safe area
- screens
- gesture handler
- SVG

C. Create ADR-003

Create:

```
docs/decisions/ADR-003-canonical-expo-version.md
```

Record:

- imported reference version
- current canonical version
- how the version changed
- compatibility evidence
- whether Expo 57/RN 0.86 is accepted
- exact remaining physical-device/EAS validation

Do not call the upgrade accepted without passing all noncredential validation below.

D. Run noncredential validation

```
cd savr-platform/mobile
npm ci
npm run lint
npm run typecheck
npm run test:unit
npx expo-doctor
npx expo export --platform android
npx expo export --platform ios
```

Run `expo prebuild --clean --no-install` in a disposable working copy or remove generated native directories afterward. Do not commit generated `android/` or `ios/` folders unless an ADR explicitly changes the managed-workflow decision.

E. Add CI

Add a mobile compatibility job covering:

- Expo Doctor
- Android export
- iOS export

Native EAS builds remain a protected-environment/manual release gate.

Do not make another major dependency upgrade in this task.

Corrective PR 5 — Implement durable AI rate limiting

Branch

```
copilot/corrective-05-api-rate-limits
```

Pull request title

```
fix: enforce durable per-user rate limits on AI endpoints
```

Objective

Replace the current always-allow rate-limit stub with an atomic Supabase-backed limit shared across Vercel instances.

Required work

A. Create a rate-limit data contract

Add a migration for:

```
public.api_rate_limit_buckets
```

Suggested key:

```
user_id  
endpoint  
window_start
```

Store:

```
request_count  
created_at  
updated_at
```

No direct client access.

B. Add an atomic consume function

Create a security-definer SQL function that accepts:

```
user ID
endpoint name
limit
window length in seconds
```

It must atomically:

- calculate the current bucket
- increment the request count
- determine allowed/blocked
- return count, remaining, and reset time
- set a safe search path
- reject invalid limits and window values

C. Replace `checkRateLimit`

Update:

```
savr-platform/web/lib/middleware.ts
```

It must use the service-role Supabase client to call the atomic function.

Do not use:

- process memory
- local maps
- client state
- an always-allow fallback

When rate-limit storage fails, fail closed for cost-bearing AI endpoints.

D. Update every AI endpoint

Search all callers of `checkRateLimit`.

Ensure each AI route:

- requires authenticated user identity
- has an explicit endpoint identifier
- returns HTTP 429 when blocked
- returns rate-limit headers

- validates its request body before calling an AI provider
- limits oversized strings, arrays, URLs, and image payloads
- does not leak provider errors or secrets

Preserve existing route-specific limits unless a separate documented decision changes them.

E. Tests

Test:

- first request allowed
- last request within limit allowed
- first request over limit blocked
- separate users have separate buckets
- separate endpoints have separate buckets
- a new window resets the count
- atomic parallel requests cannot exceed the limit unnoticed
- storage failure does not silently allow requests

Run Supabase reset and all web tests.

Corrective PR 6 — Productionize the public landing page

Branch

copilot/corrective-06-landing-page

Pull request title

feat: productionize the SAVR public landing page

Route contract

Keep:

/	public marketing landing page
/dashboard	authenticated application
/sign-in	authentication
/sign-up	account creation
/pricing	public pricing
/faq	public FAQ

Do not redirect every authenticated user away from `/`.

Preserve the existing post-Stripe checkout redirect behavior.

Required work

A. Keep and refine the existing root page

Work from:

```
savr-platform/web/app/page.tsx
```

Do not replace `/` with the dashboard.

B. Remove obsolete visual styling

Replace all obsolete usages of:

```
gradient-text-cyan  
glow-cyan  
cyan  
purple
```

Use the canonical design tokens and current utility classes:

```
gradient-text  
gradient-text-lime  
glow-primary  
glow-primary-strong
```

Remove hardcoded legacy cyan, purple, pink, and navy styling from the landing page and its public components unless it represents an explicitly retained semantic state.

C. Correct unsupported claims

Remove or rewrite claims such as:

```
Loved by thousands of home cooks  
Vet-reviewed recipes  
Cross-references every ingredient against live veterinary databases
```

Use defensible language:

SAVR applies deterministic ingredient-safety filters based on established veterinary guidance.

Pet recipes are intended as occasional treats or supplements and should be reviewed with a veterinarian.

Do not imply veterinary endorsement, live database access, user counts, ratings, or clinical validation without evidence.

D. Public-facing navigation

Replace:

Production workspace

with consumer-facing language such as:

Smart pantry and meal planning

Public desktop and mobile navigation must include:

Features
How It Works
Pricing
FAQ
Sign In
Get Started

Authenticated navigation must still provide a clear:

Open SAVR

or:

Go to Dashboard

CTA.

E. Include exact pricing

Landing-page pricing content must use:

Basic – \$4.99/month or \$49.99/year
Pro – \$9.99/month or \$99.99/year

Link to `/pricing`.

Do not add other tiers.

F. SEO and social metadata

Add:

- canonical URL
- Open Graph title, description, URL, and image
- Twitter card metadata
- robots metadata
- sitemap
- descriptive page title and description
- structured software/product data where accurate

Use the canonical production domain configuration rather than hardcoding preview hosts.

G. Analytics cleanup

Replace the two hardcoded Google Analytics properties with one environment-controlled property:

`NEXT_PUBLIC_GA_MEASUREMENT_ID=`

Load analytics only when configured.

Do not load duplicate Google Analytics scripts.

Respect the existing privacy policy and add a consent mechanism before nonessential analytics when required by the selected deployment jurisdiction and policy.

H. Landing-page tests

Expand Playwright coverage for desktop and mobile:

- hero heading
- Basic and Pro pricing
- sign-up CTA

- sign-in CTA
- pricing link
- FAQ link
- authenticated dashboard CTA
- no broken public navigation links
- no horizontal overflow at 390px
- keyboard navigation
- visible focus states
- reduced-motion behavior
- post-checkout redirect remains intact

Run web lint, typecheck, unit tests, build, and smoke E2E.

Corrective PR 7 — Complete mobile authentication readiness

Branch

```
copilot/corrective-07-mobile-auth
```

Pull request title

```
fix: complete Expo Google authentication and release redirects
```

Objective

Replace the mobile Google sign-in placeholder with an Expo-compatible Supabase OAuth flow.

Required work

Use the already installed Expo authentication and browser packages.

Implement:

- expo-auth-session
- expo-web-browser
- Supabase OAuth URL generation
- SAVR application deep-link callback
- session exchange after callback
- canceled-login handling
- browser-error handling
- invalid-callback handling
- loading-state protection

- redirect URL configuration through `app.config.ts`

Use scheme:

saVR

Document the exact Supabase redirect URL and Google OAuth client configuration required for:

- development
- Expo Go where supported
- Android standalone build
- iOS standalone build

Do not place Google client secrets in `EXPO_PUBLIC_*` variables.

Add tests for the callback parser and session-exchange decision logic.

Validate with Expo Doctor, lint, typecheck, unit tests, and Android/iOS exports.

Record physical-device validation as required before release.

Corrective PR 8 — Final release-candidate verification

Branch

`copilot/corrective-08-release-candidate`

Pull request title

`chore: establish SAVR release-candidate evidence`

Objective

Create one auditable release-candidate gate after all corrective PRs are merged.

Required work

A. Clean project status

Rewrite `MIGRATION_STATUS.md` as a concise current-state document.

Retain a link to historical phase information rather than duplicating contradictory phase summaries.

Current status must clearly distinguish:

- implemented
- CI-validated
- externally validated
- manually pending
- blocked

B. Resolve documentation status

Update:

```
docs/validation/required-gates.md
savr-platform/README.md
SOURCE_ORIGINS.md
```

Verify ADR statuses accurately reflect reality.

Do not mark ADR-002 resolved without production storage evidence.

C. Protect debug surfaces

Review:

```
/subscription-debug
```

Either:

- remove it from production, or
- protect it behind an explicit development/admin guard

It must not expose customer or subscription information publicly.

D. Run the full nonsecret suite

```
node scripts/validate-copilot-instructions.mjs
bash scripts/verify-reference-integrity.sh

cd savr-platform/web
npm ci
npm run lint
npm run typecheck
```

```

npm run test:unit
npm audit --audit-level=high
CI=true
NEXT_PUBLIC_SUPABASE_URL=https://dummy.supabase.co
NEXT_PUBLIC_SUPABASE_ANON_KEY=dummy_key_for_build
npm run build

cd ../mobile
npm ci
npm run lint
npm run typecheck
npm run test:unit
npm audit --audit-level=high
npx expo-doctor
npx expo export --platform android
npx expo export --platform ios

cd ../e2e-tests
PLAYWRIGHT_USE_WEBSERVER=true
CI=true
NEXT_PUBLIC_SUPABASE_URL=https://dummy.supabase.co
NEXT_PUBLIC_SUPABASE_ANON_KEY=dummy_key_for_build
npm run test:e2e:smoke

cd ..
npx supabase@latest db reset

```

E. Create protected live-environment tests

Create workflows requiring the GitHub `Production` or `Staging` environment for:

- real Supabase authenticated CRUD smoke test
- Stripe test-mode checkout
- Stripe webhook delivery
- Basic monthly entitlement
- Basic yearly entitlement
- Pro monthly entitlement
- Pro yearly entitlement
- customer portal
- subscription cancellation
- subscription upgrade/downgrade
- AI request and durable rate-limit behavior

Never expose secrets to pull requests from forks.

F. Native release evidence

Require:

- one Android EAS preview build
- one iOS EAS preview build
- login test
- camera permission test
- pantry image upload test
- recipe generation test
- logout/login persistence test

These may remain manual checklist entries until signing credentials are configured, but they must not be reported as passed without actual evidence.

G. Release report

Create:

```
docs/validation/RELEASE_CANDIDATE_REPORT.md
```

Include:

- commit SHA
- workflow links
- deployed preview URL
- database migration result
- Stripe test results
- Android build identifier
- iOS build identifier
- known limitations
- rollback plan
- final go/no-go recommendation

Do not auto-merge this PR.